

Arquitectura de Seguridad - Largo Plazo (6-12+ meses)

Caso Bankitor - TO-BE

1. Punto de Partida

El largo plazo consolida una arquitectura de seguridad madura. Bankitor ya tiene operativo lo del corto y mediano plazo:

Del corto plazo: Router con trazabilidad, WAF, Firewall HA, SIEM/SOC activo, Auditoría SQL, MFA, Bastion.

Del mediano plazo: IDS/IPS, PAM completo, VLANs internas, Gestión de vulnerabilidades, DLP básico, pruebas de continuidad.

El largo plazo da el salto hacia una arquitectura proactiva, centrada en identidad, con automatización de respuesta y alineación con marcos de referencia como Zero Trust y NIST CSF.

2. Objetivo del Largo Plazo

Transformar la postura de seguridad de Bankitor de reactiva a proactiva, implementando Zero Trust de forma progresiva, automatizando la respuesta a incidentes y elevando la madurez del SOC.

Duración: Meses 7 al 12 (y más allá)

Enfoque: Zero Trust, SOAR, UEBA, microsegmentación, DevSecOps, inteligencia de amenazas.

3. Nuevos Componentes Incorporados

3.1 Zero Trust - Arquitectura de Confianza Cero

Principio:

"Nunca confíes, siempre verifica." — No existe la red confiable. Toda solicitud de acceso debe autenticarse, autorizarse y verificarse, independientemente de si viene de dentro o

fuera de la red.

Por qué es el paso final y no el primero:

Zero Trust requiere que ya existan:

- Inventario de activos completo (mediano plazo: escáner de vulnerabilidades).
- Segmentación de red (mediano plazo: VLANs).
- Gestión de identidades robusta (corto/mediano: MFA + PAM).
- Visibilidad de tráfico (corto: SIEM, mediano: IDS/IPS).

Pilares de Zero Trust aplicados a Bankitor:

Pilar	Implementación en Bankitor
Identidad	MFA + PAM + verificación continua de sesión
Dispositivo	EDR + validación de postura del endpoint antes de acceder
Red	Microsegmentación. Acceso solo al recurso necesario
Aplicación	WAF + API Gateway + autenticación por aplicación
Datos	DLP completo + clasificación + cifrado

Implementación progresiva (no de golpe):

1. Comenzar con accesos privilegiados (ya hecho con PAM).
2. Aplicar Zero Trust a banca por Internet (verificación de dispositivo + comportamiento).
3. Extender a usuarios internos.
4. Aplicar a aplicaciones críticas (BD de créditos).

3.2 SOAR - Automatización de Respuesta a Incidentes

Qué es:

SOAR (Security Orchestration, Automation and Response) permite que el SOC responda automáticamente a ciertos tipos de incidentes según playbooks definidos.

Por qué en largo plazo:

Requiere que el SIEM esté maduro, los casos de uso estén bien definidos y el SOC tenga experiencia con las alertas. Si se implementa antes de esa madurez, los playbooks automáticos pueden causar más daño que bien.

Ejemplos de playbooks automatizados para Bankitor:

Escenario	Acción automática del SOAR
IP atacando el WAF más de 100 veces en 5 min	Bloquear IP en WAF y Firewall automáticamente
Cuenta DBA activa fuera de horario	Suspender sesión + notificar gerente + abrir ticket
Modificación masiva en tabla de créditos	Bloquear acceso a BD + alerta crítica + escalar a CISO
Malware detectado por EDR	Aislar equipo de red + iniciar análisis forense
Login fallido desde 20 IPs distintas	Bloquear IPs + activar captcha en banca web
Router sin backup en 48h	Alerta automática al equipo de redes

Beneficio directo para Bankitor:

En el incidente de la BD de créditos, si hubiera habido SOAR, el bloqueo de la cuenta que hizo el cambio habría sido automático en segundos, no horas o días después.

3.3 UEBA - Análisis de Comportamiento de Usuario

Qué es:

UEBA (User and Entity Behavior Analytics) analiza el comportamiento normal de usuarios y entidades (servidores, aplicaciones) para detectar anomalías.

Diferencia con el SIEM:

- El SIEM detecta eventos basado en reglas.
- El UEBA detecta comportamientos anómalos usando línea base y machine learning.

Ejemplos de detección UEBA en Bankitor:

Comportamiento anómalo	Qué detecta UEBA
DBA que normalmente trabaja de 9 a 18 y de repente se conecta a las 2 AM	Anomalía de horario
Consulta a 10,000 filas de tabla de créditos cuando lo normal es 50	Anomalía de volumen
Administrador de router que descarga la configuración completa por primera vez	Anomalía de actividad
Usuario que en un día accede desde Lima y luego desde otra ciudad	Anomalía de geolocalización

Comportamiento anómalo	Qué detecta UEBA
Servidor que de repente abre conexiones hacia Internet	Anomalía de entidad

Relación directa con incidente Bankitor:

El cambio de saldos a cero habría sido detectado por UEBA como un comportamiento anómalo de la cuenta de aplicación que lo hizo, incluso si el SIEM no tenía una regla específica para ese escenario.

3.4 Microsegmentación

Qué es:

Segmentación a nivel de carga de trabajo (workload), no solo de red. Cada aplicación, servidor o proceso se comunica solo con lo que necesita, y nada más.

Diferencia con VLANs:

VLAN (mediano plazo)	Microsegmentación (largo plazo)
Segmenta por segmento de red	Segmenta por aplicación o proceso
Control a nivel L2/L3	Control a nivel L4-L7
Granularidad media	Granularidad alta
Relativo al firewall perimetral	Aplicado directamente en cada host

Aplicación en Bankitor:

- El servidor web solo puede hablar con el servidor de aplicaciones en el puerto 8080.
- El servidor de aplicaciones solo puede hablar con la BD en el puerto 5432 (PostgreSQL) o 1521 (Oracle).
- La BD no puede iniciar ninguna conexión saliente.
- Si un servidor es comprometido, no puede moverse libremente, ni siquiera dentro de su VLAN.

3.5 API Gateway

Qué es:

Punto único de entrada para todas las APIs de banca digital (web y móvil).

Por qué en largo plazo:

Bankitor probablemente ya tiene APIs para banca por Internet. En corto plazo se protegen con WAF. En largo plazo se implementa un API Gateway dedicado con funciones avanzadas.

Funciones del API Gateway:

Función	Beneficio
Autenticación y autorización de APIs	Solo tokens válidos acceden
Rate limiting por cliente	Previene abuso y fuerza bruta
Validación de esquema	Rechaza payloads malformados
Enmascaramiento de datos	Oculto campos sensibles en respuestas
Versionamiento	Gestiona versiones antiguas y nuevas de API
Logging centralizado	Visibilidad completa de uso de API
Circuit breaker	Protege servidores de sobrecarga

3.6 DevSecOps

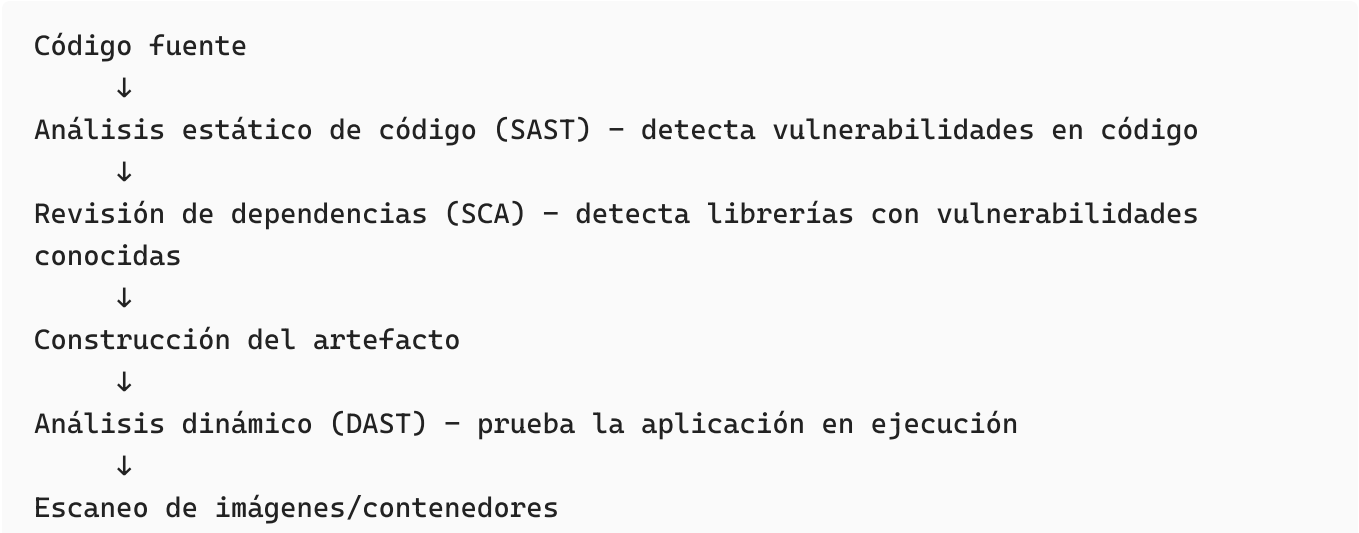
Qué es:

Integración de seguridad en el proceso de desarrollo de software desde el principio, no como revisión final.

Por qué en largo plazo:

Requiere cambio cultural, capacitación de desarrolladores y cambios en el proceso de entrega de software. No se puede implementar en 3 meses.

Pipeline seguro para Bankitor:





Aprobación de seguridad



Despliegue a producción

Beneficio:

Las vulnerabilidades se detectan y corrigen en el desarrollo, no después de estar en producción. Reduce drásticamente el costo de remediación.

3.7 Threat Intelligence - Inteligencia de Amenazas

Qué es:

Consumo de fuentes de información sobre amenazas actuales, IPs maliciosas, dominios C2, actores de amenaza, TTPs (Tácticas, Técnicas y Procedimientos).

Cómo se usa en Bankitor:

Fuente	Uso
Feeds de IPs maliciosas	Bloqueo automático en Firewall y WAF
Indicadores de compromiso (IoC)	Búsqueda en logs del SIEM
Alertas de sector financiero (FS-ISAC)	Advertencia anticipada de campañas contra bancos
Boletines de vulnerabilidades (CISA, CERT)	Priorización de parches
Dark web monitoring	Detectar si credenciales de Bankitor están filtradas

3.8 Red Team / Ejercicios de Simulación

Qué es:

Equipo de profesionales que simula ataques reales contra Bankitor para identificar vulnerabilidades que los controles técnicos no detectaron.

Tipos de ejercicios:

Ejercicio	Descripción
Pentest anual	Prueba de penetración de infraestructura y aplicaciones
Red Team completo	Simulación de atacante real con acceso a personas, procesos y tecnología
Purple Team	Red Team y Blue Team (SOC) trabajan juntos para mejorar detección
Simulacro de phishing avanzado	Campaña de phishing dirigida a empleados clave
Tabletop exercise	Simulación de incidente a nivel ejecutivo para evaluar respuesta

Frecuencia recomendada:

- Pentest de aplicaciones web: semestral.
- Pentest de infraestructura: anual.
- Red Team completo: anual.
- Tabletop ejercicio: semestral.

3.9 DLP Completo (Endpoint + Nube)

Evolución del DLP básico del mediano plazo:

Nivel	Mediano Plazo	Largo Plazo
Correo	Sí	Sí (mejorado)
Proxy/Web	Sí	Sí (mejorado)
Endpoint	No	Sí
Nube	No	Sí
Bases de datos	No	Sí (enmascaramiento)

DLP Endpoint:

- Controla copia a USB, impresión, captura de pantalla.
- Bloquea envío de archivos sensibles por cualquier canal.

DLP en Nube:

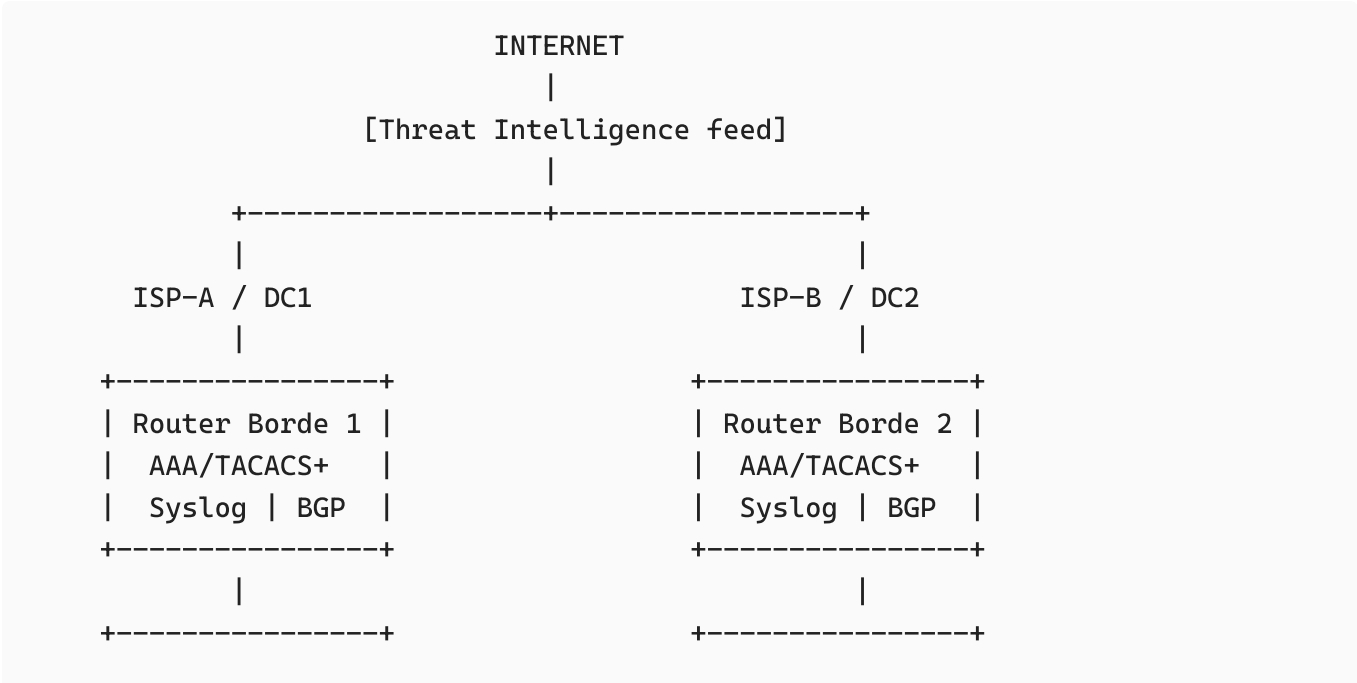
- Si Bankitor usa servicios cloud (Office 365, etc.), controla que datos sensibles no salgan.

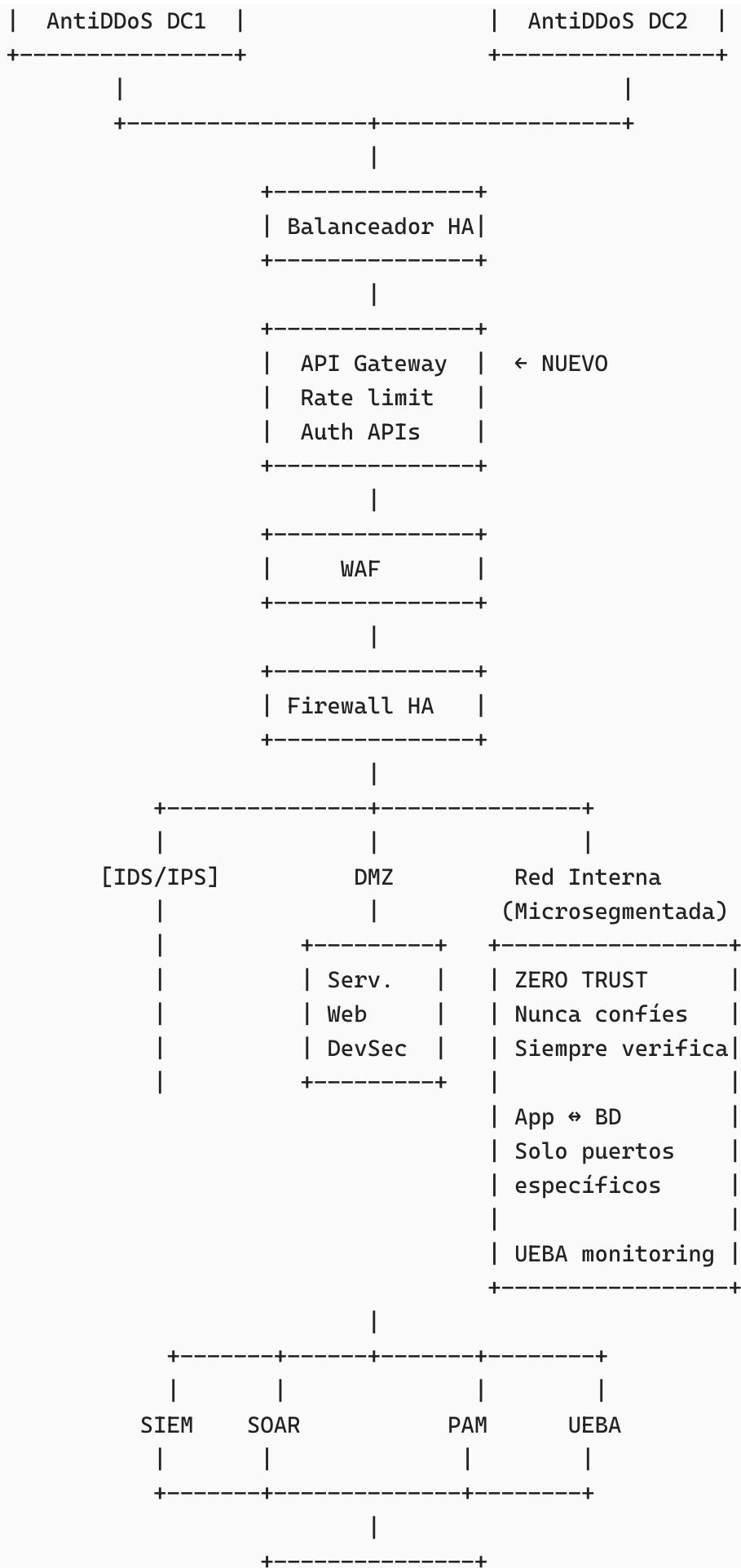
3.10 CISO y Gobierno de Seguridad

Qué se consolida:

Elemento	Descripción
Programa de seguridad formal	Roadmap de seguridad aprobado por directorio
Métricas e indicadores KPI	Tiempo de detección, tiempo de respuesta, vulnerabilidades pendientes
Comité de seguridad	Reuniones periódicas con gerencias para revisar postura de seguridad
Gestión de riesgo tecnológico	Alineado con SBS y NIST
Audidores internos y externos	Revisión independiente de controles
Programa de Bug Bounty	Investigadores externos reportan vulnerabilidades de forma responsable

4. Arquitectura TO-BE Largo Plazo - Resumen Visual





```
| SOC Maduro |
| Playbooks  |
| Auto-respuesta|
| Red Team   |
| Threat Intel|
+-----+
```

Gobierno: CISO → Comité Seguridad → Directorio → SBS
DevSecOps: Código → SAST → SCA → DAST → Producción

5. Evolución Total de la Arquitectura

Componente	AS-IS (Antes)	Corto Plazo (3m)	Mediano Plazo (6m)	Largo Plazo (12m+)
Router	Sin trazabilidad	AAA + Syslog + Backup	Igual + hardening protocolos	Igual + Threat Intel
Firewall	Básico	HA + Logs SIEM	Igual + reglas VLAN	Igual + microsegmentación
Detección web	Sin WAF	WAF activo	WAF + calibrado	WAF + API Gateway
Acceso admin	Directo	MFA + Bastion	PAM básico	PAM + Zero Trust
BD créditos	Sin auditoría	Auditoría SQL	Igual + VLAN aislada	Igual + enmascaramiento
Visibilidad	Sin SIEM	SIEM + casos base	SIEM + IDS/IPS/PAM	SIEM + SOAR + UEBA
Respuesta	Manual/tardía	SOC alertado	SOC con playbooks	SOAR automatizado
Segmentación	Básica	DMZ vs Interna	VLANs por función	Microsegmentación
Vulnerabilidades	Sin proceso	Ad-hoc	Escáner formal	DevSecOps + Red Team
Datos	Sin DLP	Sin DLP	DLP correo/proxy	DLP endpoint + nube
Arquitectura	Sin modelo	Defensa profundidad	Defensa + visibilidad	Zero Trust

6. Indicadores de Madurez (KPIs)

Al finalizar el largo plazo, Bankitor debería poder medir:

KPI	Objetivo
MTTD (Tiempo medio de detección)	< 1 hora para incidentes críticos
MTTR (Tiempo medio de respuesta)	< 4 horas para incidentes críticos
Cobertura de activos en SIEM	> 95% de sistemas críticos enviando logs
Vulnerabilidades críticas sin parche	0 después de 72 horas
Sesiones PAM sin grabación	0%
Accesos sin MFA a sistemas críticos	0%
Ejercicios de Red Team al año	Al menos 1
Score NIST CSF	Objetivo: nivel 4 (Managed)

7. Alineación Regulatoria (SBS)

Normativa SBS	Control implementado
Circular G-140-2009 Seguridad de Información	SIEM, auditoría, controles de acceso
Resolución SBS 272-2017 (Gestión de Riesgo Operacional)	BCP, pruebas de continuidad, RTO/RPO
Lineamientos de ciberseguridad SBS (2023)	SOC, gestión de vulnerabilidades, Zero Trust
NIST CSF	Identificar, Proteger, Detectar, Responder, Recuperar
ISO 27001	Marco de gobierno y gestión de seguridad de la información

8. Actividades del Largo Plazo (meses 7-12+)

Meses 7-8

- ☐ Implementar SOAR con primeros playbooks: bloqueo de IP, aislamiento de endpoint, escalamiento de alertas.

- ☐ Integrar Threat Intelligence al Firewall y WAF (bloqueo automático de IPs maliciosas).
- ☐ Implementar API Gateway para banca digital.
- ☐ Iniciar diseño de microsegmentación.

Meses 9-10

- ☐ Implementar UEBA sobre el SIEM existente.
- ☐ Desplegar DLP endpoint en equipos de DBAs y administradores.
- ☐ Realizar primer pentest completo de infraestructura y aplicaciones.
- ☐ Implementar microsegmentación en servidores críticos (BD, Web).

Meses 11-12

- ☐ Implementar pipeline DevSecOps para nuevas aplicaciones.
- ☐ Realizar ejercicio de Red Team.
- ☐ Consolidar governance de seguridad: métricas, comité, reportes a directorio.
- ☐ Evaluar alineación con ISO 27001 o certificación.
- ☐ Revisar cobertura DLP en nube si se usan servicios cloud.
- ☐ Documentar postura de seguridad para reporte regulatorio SBS.

9. Supuestos Adicionales para Largo Plazo

1. El SOAR se integra con el SIEM existente (no es un reemplazo).
2. El UEBA puede ser un módulo del SIEM o una solución separada integrada.
3. La microsegmentación se implementa con tecnología de firewall de host o solución dedicada (p.ej. Illumio, Guardicore).
4. El API Gateway es un componente nuevo, no el WAF existente (aunque ambos se complementan).
5. DevSecOps aplica a nuevos desarrollos; las aplicaciones legacy se escanean periódicamente con DAST.
6. El programa de Bug Bounty comienza privado (solo investigadores invitados) antes de ser público.

Documento: Arquitectura de Seguridad Bankitor - Largo Plazo (6-12+ meses)

Clasificación: Uso interno - Trabajo académico ESAN